Gateproof KISA 점검 보고서

대상

- 프로젝트: `examples/demo-api/`
- 점검 트랙: `gateproof:kisa-check`

종합 의견

이 대상은 현재 상태로 KISA 성격의 기본 점검 통과 가능성이 낮습니다. 관리자 노출 통제, 비밀정보 관리, 로그인 보호, 로그 위생, 운영 증적 측면에서 모두 명확한 결함이 보입니다.

문제는 일부 항목이 단순히 문서가 없는 수준이 아니라, 실제 구현이 실패 방향으로 고정돼 있다는 점입니다. 특히 관리자 라우트 공개, 코드 내 비밀정보, 민감 로그인 로그는 우선순위가 높은 개선 대상입니다.

핵심 실패 항목

`KISA-ACS-01` 관리자 표면 최소화

- 판정: Fail
- 근거:
  - `config/ingress.yaml`의 `admin.demo.example.com`
  - `src/server.js`의 인증 없는 `/admin/users`
- 의미:
  - 관리자 표면이 공개되어 있고, 실질적인 접근 차단이 없습니다.

`KISA-ENC-02` 비밀정보 외부화

- 판정: Fail
- 근거:
  - `src/auth.js`의 `JWT_SECRET` 기본 문자열
  - 같은 파일의 커밋된 사용자 비밀번호
- 의미:
  - 비밀정보와 자격증명이 런타임이 아니라 소스에 남아 있습니다.

`KISA-LOG-04` 민감정보 로그 마스킹

- 판정: Fail
- 근거:
  - `src/server.js`에서 로그인 요청 본문을 기록
- 의미:
  - 인증 정보가 로그를 통해 유출될 수 있습니다.

`KISA-ACC-04` 로그인 실패 제한

- 판정: Fail

- 근거:
  - `/login` 주변에 throttling, lockout, abuse control 증적이 없음
- 의미:
  - 무차별 대입이나 크리덴셜 스터핑에 취약합니다.

보조 판정

컨트롤	판정	메모
KISA-ACC-01	Partial	특권 원격 로그인 통제 증적이 부족
KISA-ACC-02	Partial	역할은 있으나 관리자 경계가 약함
KISA-ACC-03	Fail	약한 비밀번호와 정책 부재
KISA-ACS-02	Partial	일부 사용자 경계는 있으나 관리자 우회 존재
KISA-ACS-03	Fail	공개 API와 관리자 호스트가 같은 백엔드로 노출
KISA-ENC-01	Fail	TLS 강제 증적이 보이지 않음
KISA-LOG-02	Fail	관리자 행위에 대한 감사 경계가 약함
KISA-HRD-04	Fail	CI에서 운영 비밀 다루는 방식이 unsafe

우선 조치

1. 관리자 호스트 공개를 제거하고 `/admin/users`에 관리자 권한검사를 적용합니다.
2. 코드 내 비밀정보와 자격증명을 제거하고 런타임 주입 방식으로 전환합니다.
3. 로그인 요청 본문 로깅을 중단하고 안전한 인증 이벤트 로그만 남깁니다.
4. 로그인 시도 제한 또는 잠금 제어를 추가합니다.
5. CI에서 운영 비밀을 출력하지 않도록 워크플로를 분리합니다.